

APT REPORTS

The ‘Penquin’ Turla

08 DEC 2014 4 minute read

Expert KURT BAUMGARTNER Expert COSTIN RAIU

A Turla/Snake/Uroburos Malware for Linux

Recently, an interesting malicious sample was uploaded to a multi-scanner service. This immediately triggered our interest because it appears to represent a previously unknown piece of a larger puzzle. That puzzle is “Turla”, one of the most complex APTs in the world.

We have written previously about the Turla APT with posts about their Epic Turla operations and Agent.btz inspiration.

So far, every single Turla sample we've encountered was designed for the Microsoft Windows family, 32 and 64 bit operating systems. The newly discovered Turla sample is unusual in the fact that it's the **first Turla sample targeting the Linux operating system** that we have discovered.

This newly found Turla component supports Linux for broader system support at victim sites. The attack tool takes us further into the set alongside the Snake rootkit and components first associated with this actor a couple years ago. We suspect that this component was running for years at a victim site, but do not have concrete data to support that statement just yet.

The Linux Turla module is a C/C++ executable statically linked against multiple libraries, greatly increasing its file size. It was stripped of symbol information, more likely intended to increase analysis effort than to decrease file size. Its functionality includes hidden network communications, arbitrary remote command execution, and remote management. Much of its code is based on public sources.

Md5	Size	Verdict Name
0994d9deb50352e76b0322f48ee576c6	627.2 kb	N/A (broken file)
14ecd5e6fc8e501037b54ca263896a11	637.6 kb	HEUR:Backdoor.Linux.Turla.gen

General executable characteristics:

ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), statically linked, for GNU/Linux 2.2.5, stripped

Statically linked libraries:

- glibc2.3.2 – the GNU C library
- openssl v0.9.6 – an older OpenSSL library
- libpcap – tcpdump's network capture library

Hardcoded C&C, known Turla activity: **news-bbc.podzone[.]org**
The domain has the following pDNS IP: **80.248.65.183**

```
80.248.65.183
aut-num:        AS30982
announcement:   80.248.65.0/24
as-name:        CAFENET
descr:          CAFE Informatique et telecommunications
admin-c:        YN2-AFRINIC
tech-c:         AN39-AFRINIC
org:            ORG-CIet1-AFRINIC
mnt-by:         AFRINIC-HM-MNT
mnt-lower:      CAFENET-NOC
source:         AFRINIC # Filtered
```

Note: the C&C domain is currently sinkholed by Kaspersky Lab.

Functional description

The sample is a stealth backdoor based on the cd00r sources.

This Turla cd00r-based malware maintains stealth without requiring elevated privileges while running arbitrary remote commands. It can't be discovered via netstat, a commonly used administrative tool. It uses techniques that don't require root access, which allows it to be more freely run on more victim hosts. Even if a regular user with limited privileges launches it, it can continue to intercept incoming packets and run incoming commands on the system.

Startup and Execution

To start execution, the process requires two parameters: ID (a numeric value used as a part of the "magic packet for authentication") and an existing network interface name. The parameters can be inputted two different ways: from STDIN, or from dropper a launching the sample. This is NOT a command-line parameter, it's a real prompt asking the attacker user to provide the input parameters. After the ID and interface name are entered and the process launched, the backdoor's process PID is returned. Here is a screenshot of this simple interface:


Penquin_2

While there is no initial network callback, a section of code maintains a hardcoded c2 string "news-bbc.podzone[.]org". This fully qualified domain name was first set up in 2010, suggesting that this binary is fairly recent in the string of Turla campaigns. Also, while we haven't seen additional file download activity from this server by this tool, it likely participated as a file server of sorts.

Magic Packets for Remote Command Execution

The module statically links PCAP libraries, and uses this code to get a raw socket, applies a filter on it, and captures packets, checking for a specific condition (the *original cd00r first used this method, based on ports and SYN-packets). This condition is expressed here (it is based on the ID value input at startup by the attacker):

> ID = 123 Filter = (tcp[8:4] & 0xe007ffff = 0xe003bebe) or (udp[12:4] & 0xe007ffff = 0xe003bebe) ID = 321 Filter = (tcp[8:4] & 0xe007ffff = 0x1bebe) or (udp[12:4] & 0xe007ffff = 0x1bebe)

In simple terms, it checks for an ACK number in the TCP header, or the second byte from the UDP packet body.

If such a packet is received and the condition check is successful, execution jumps to the packet payload contents, and it creates a regular socket. The backdoor handles this socket as a file with read/write operations. It's not the typical recv/send used in this code. It uses this new socket to connect to the source address of the "magic packets". Then it reports its own PID and IP to the

remote address, and starts an endless loop for receiving remote commands. When a command arrives, it is executed with a "/bin/sh -c " script.

Further analysis of the sample's functionality will be updated here.

Conclusions

Although Linux variants from the Turla framework were known to exist, we haven't seen any in the wild yet.

This specific module appears to have been put together from public sources with some added functionality from the attackers. Some of the malicious code appears to be inactive, perhaps leftovers from older versions of the implant. Perhaps the most interesting part here is the unusual command and control mechanism based on TCP/UDP packets, as well as the C&C hostname which fits previously known Turla activity.

The discovery of this Turla module rises one big question: how many other unknown Turla variants exist?

Update: Since the publishing of this blogpost, we have discovered another Linux Turla module, which apparently represents a different malware generation than the previously known samples:



The new sample was heuristically detected by our product due to similarities with the previously discovered samples.

Md5	Size	Verdict Name
19fbd8cbfb12482e8020a887d6427315	801,561 bytes	HEUR:Backdoor.Linux.Turla.gen

Related research:

- BAE Systems – The Snake Campaign
- Kaspersky Lab – The Epic Turla Operation
- "TR-25 Analysis – Turla / Pfinet / Snake/ Uroburos" by CIRCL.LU
- "Uroburos: the snake rootkit", technical analysis by deresz and tecamac
- Agent.BTZ – A Source of Inspiration?

TURLA BACKDOOR APT LINUX

The ‘Penquin’ Turla

Your email address will not be published. Required fields are marked *

Type your comment here

Name *

Email *

Comment

This site uses Akismet to reduce spam. Learn how your comment data is processed.

ALAN JENKINS
Posted on December 8, 2014. 9:13 pm

“without requiring elevated privileges” “links PCAP libraries, and uses this code to get a raw socket”

You’re very confident about this. However my understanding was you can’t capture packets / open raw sockets without root. Surely that’s big news? Are you going to elaborate on it?

Reply

ERIC SEBASTA
Posted on December 12, 2014. 5:44 am

If the code it is build into code RUNS as root, you certainly can capture packets and open sockets though. And hell no I am not personally elaborating, or some 12 year old will write another one lol.

Reply

CHRISTIAN PAPATHANASIOU
Posted on December 9, 2014. 10:37 am

cd00r is hardly new or sophisticated…… we’re talking about circa 2002 rootkit technology….. why all the excitement?

Reply

HANS-WERNER HILSE
Posted on December 9, 2014. 1:12 pm

RAW socket access is supposed to need at least CAP_NET_RAW capabilities. So not strictly root, but in practice, of course, it starts from there.

Reply

DAVID
Posted on December 9, 2014. 4:08 pm

How does this malware get onto a linux system in the first place? what is the attack vector?

Reply

MALCOLM JAROS
Posted on December 9, 2014. 4:31 pm

So, the $64 000 question: How can we check for and, if necessary, take evasive action against this threat?

Reply



TILGHMAN LESHER
Posted on December 9, 2014. 7:27 pm

Your best bet would be to blackhole the domain listed as hardcoded C&C domain. The IP, in fact, has already changed from what is published here, so trying to blackhole that IP address would be useless. If that domain either resolves to the localhost address, or possibly doesn't resolve, then as the trojan would be unable to contact its C&C host, it would presumably shut down, or, at the very least, fail to take any further instructions.

Reply

OUTRE99
Posted on December 9, 2014. 5:03 pm

Thanks for finding and describing this threat.
How do we defend against it? There's no mention of this very important topic. Being an security expert this seems like a strange oversight on your part.

Reply

JACK
Posted on December 10, 2014. 6:01 am

...probably keep with the software updates, as much as possible anyway. The article states that it hasn't been seen yet "in the wild", so it probably is most likely not running on your local desktop. That said, should it become something worth worrying about, I'm hoping that there will be some kind of patch or detection mechanism from the usual linux players – Red Hat, Ubuntu, etc.

Reply

TOKYOJOHN
Posted on December 9, 2014. 10:19 pm

I think the instructions are quite clear: 1) be aware, 2) don't panic.

Reply

UROBOROS
Posted on December 9, 2014. 10:28 pm

It seems as a hoax. Be carefull about this hystery. Unless it is verified it means nothing.

Thats only way how to decrease linux market share for servers and growing desktop interest – with FUD and uncertainty.
Yes, linux is much more secure than windows that it is not worth to do antivirus for it. Without viruses lot of companies will loose their job.

Reply



SLY_TOM_CAT
Posted on December 11, 2014. 12:15 pm

https://kasperskycontenthub.com/securelist/files/2014/12/Penquin_2.jpg – ups!
isnt that (#) root shell was used to start the troyan? 🙂

Again again and again the Eugeny Kasperskiy epic fail!

Reply



TOMAS
Posted on December 12, 2014. 9:06 pm

Security experts…

Reply

PETER L
Posted on December 11, 2014. 3:29 pm

Quick & Dirty way to check:
find $(mount|awk '$5~/ext/{print $3}') -xdev -type f -size +600k -size -800k -exec md5sum {} \+ | grep -E '0994d9deb50352e76b0322f48ee576c6|14ecd5e6fc8e501037b54ca263896a11|19fbd8cbfb12482e8020a887d6427315'

Reply

ME
Posted on December 12, 2014. 1:54 am

Peter L, thank you. simple enough but this late at night i would not have figured any more.

Reply

CRAIG JUNGERS
Posted on December 12, 2014. 6:46 pm

Good idea but I'm getting errors on Fedora 20 (tried before trying it on Centos):
awk: cmd. line:1: '~/ext/{print
awk: cmd. line:1: ^ invalid char '' in expression
bash: 14ecd5e6fc8e501037b54ca263896a11: command not found…
bash: 19fbd8cbfb12482e8020a887d6427315': command not found…

Granted, I'm no awk expert … executed as root and have not tried to troubleshoot it.

Reply



SHOKORA
Posted on December 16, 2014. 10:24 pm

So let me get this straight, you are not fully aware of what the code does but yet you decided to run it as root? Living on the edge indeed.

Reply

TINKSTER
Posted on December 18, 2014. 2:32 am

You don't need to be an awk expert to notice that either the web-software or the poster inadvertently created "mixed" quotes. All statements that should be enclosed in a pair of single-quotes seem to be using an opening back-tick and a closing single quote …

/me shrugs

Reply

TINKSTER
Posted on December 18, 2014. 2:34 am

And looking at my own response it's the web-software that stuffed up, I used the SAME variety of double quotes above.

/me shrugs

Reply

TS
Posted on December 23, 2014. 11:54 pm

@Craig, the command works, but you must change ‘ (u+2018) and ’ (u+2019) to ' (simple apostrophe sign) …

but still it needs sudo, because it searches all your data for files of size between 600 and 800 kB and of name containing either 0994d9deb50352e76b0322f48ee576c6 or 14ecd5e6fc8e501037b54ca263896a11 or 19fbd8cbfb12482e8020a887d6427315

the code without u+201{8,9}:

find $(mount|awk '$5~/ext/{print $3}') -xdev -type f -size +600k -size -800k -exec md5sum {} \+ | grep -E '0994d9deb50352e76b0322f48ee576c6|14ecd5e6fc8e501037b54ca263896a11|19fbd8cbfb12482e8020a887d6427315'

Reply



PRADEEP KUMAR
Posted on December 12, 2014. 1:27 am

Why is the process started as a root user ? If you say there is no need for root access, it could have been started by a normal user.

Reply

CRAIG JUNGERS
Posted on December 12, 2014. 6:41 pm

It needs to be installed somehow as a kernel module and only a root user can do that. Regular users don't have the ability to do that. If it's a system process it doesn't need "root" because the system is doing it (just like you don't need "root" to start your computer).

Reply

CRAIG JUNGERS
Posted on December 12, 2014. 5:27 pm

I wonder if they're using "insmod" to insert the Turla code into kernel space. It would take someone with root access to do that but once it's in there it needs no escalating and, depending upon the mod code, could pretty much have the run of the system.

Reply



3R0S
Posted on December 13, 2014. 12:46 pm

This is only Microsoft and its Trolls FUD campaign to discredit Linux !!!

Reply

OXCC
Posted on December 16, 2014. 9:21 am

hi I have just started ,I want to ask a question,When analyzing a Linux malicious code,What's the matter with your IDA mark those functions?
youself make ida sig to linux lib?

Reply

BOBO
Posted on May 8, 2015. 9:13 pm

This is not FUD, this is stupidity and illiteracy!

Reply

THE ARMADILLO
Posted on June 7, 2017. 5:16 pm

It's possible they took advantage of a know kernel error in which takes advantage of an error when RAM space is created or something like that, that allows privileges to be esculated

Reply

// LATEST POSTS

NightEagle targets Russian companies

STANISLAV LARINSKY, KASPERSKY SECURITY SERVICES

Angry Birds: Toy Ghouls' new toys

KASPERSKY GERT, KASPERSKY SECURITY SERVICES

Mirage Kitten targeting aviation and FinTech sectors across the Middle East and Africa with a new malware set

OMAR AMIN

ValleyRAT masquerading as adware

PAVEL BUKHTENKO

// LATEST WEBINARS

TRAININGS AND WORKSHOPS

04 AUG 2026, 5:00PM 67 MIN

SOC maturity model. What suits your business the most?

ROMAN NAZAROV, MATEUS SALGADO

CYBERTHREAT TALKS

16 JUL 2026, 5:00PM 45 MIN

From easy target to ready business: A practical SMB cybersecurity guide

IGOR KUZNETSOV, MARIA STEPINA

CYBERTHREAT TALKS

11 JUN 2026, 5:00PM 43 MIN

The dark side of mobile: Threats targeting Android & iOS

FABIO ASSOLINI, TATYANA SHISHKOVA, DMITRY KALININ

CYBERTHREAT TALKS

25 JUN 2026, 5:00PM 29 MIN

Securing the pipeline: 2026 supply chain threats

VICTORIA VLASOVA, YAROSLAV KIKEL

// REPORTS



Mirage Kitten targeting aviation and FinTech sectors across the Middle East and Africa with a new malware set

Kaspersky researchers have discovered new Mirage Kitten attacks using previously undocumented malware families: NodeRabbit in Node.js and PollCat in JavaScript.

APT group HoneyMyte upgrades CoolClient: the backdoor gets a kernel-level Windows rootkit

Armored Likho expands its cyber-espionage toolkit

Mirage Kitten targets Middle East and Africa region with new malware

Threats

Categories

Threat Response
Webinars
Statistics
Threats descriptions

All tags
APT Logbook
Encyclopedia
KSB 2025

kaspersky

© 2026 AO Kaspersky Lab. All Rights Reserved.
Registered trademarks and service marks are the property of their respective owners.